



LAPORAN

Penetration Testing and Findings Report

Bootcamp Cyber Security [Batch 6]

Disusun oleh: Hafiz Reja Pratama

Juni 2026

DAFTAR ISI

DAFTAR ISI	2
DAFTAR GAMBAR	3
DAFTAR TABEL	4
I. EXECUTIVE SUMMARY	5
1.1 Latar Belakang	5
1.2 Tujuan Project	5
1.3 Ringkasan Risiko Bisnis	5
II. SCOPE & METHODOLOGY	6
2.1 Target Pengujian	6
2.2 Rules of Engagement (RoE)	6
III. RECONNAISSANCE & ATTACK NARRATIVE	7
3.1 RECONNAISSANCE & PORT SCANNING	7
3.2 Directoyy Brute-Forcing Menggunakan Gobuster	9
3.3 Peta Aplikasi (Application Mapping)	10
3.4 Attack Surface Matrix	11
IV. FINDING SUMMARY	12
4.1 Peringkat Tingkat Keparahan (Severity Ratings)	12
4.2 Vulnerability Summary & Report Card	14
4.3 Analisis Aktivitas Pasca-Eksploitasi	15
V. Comprehensive Technical Report	16
5.5. 1 Vuln-01: Parameter Tempering	16
5.5.2 Vuln-02: Insecure Session Management – Missing Cookie Flags (BimbyCart vs Shopee)	17
5.5.3 Vuln-03: Information Disclosure – Public Server Banner Exposure	19
5.5.4 Vuln-04: Missing Security Headers - X-Frame-Options	21
5.5.5 Vuln-05: Security Misconfiguration – Missing Content-Security-Policy (CSP)	24
VI. KESIMPULAN DAN SARAN	25
5.1 Kesimpulan	25
5.2 Saran	26
VII. REFERENSI	26

DAFTAR GAMBAR

Gambar 3. 1 Port Scanning Nmap	7
Gambar 3. 2 Brute Forcing use Gobuster.....	9
Gambar 4. 1 Analisis Pasca Eksploitasi.....	15
Gambar 5. 1 Evidence Vuln-01 (1)	16
Gambar 5. 2 Evidence Vuln-01 (2)	17
Gambar 5. 3 Evidence Vuln-03 (3)	17
Gambar 5. 4 Evidence Vuln-02 (1)	18
Gambar 5. 5 Evidence Vuln-02 (2)	19
Gambar 5. 6 Evidence Vuln-03 (1)	20
Gambar 5. 7 Evidence Vuln-03 (2)	20
Gambar 5. 8 Evidence Vuln-04 (1)	22
Gambar 5. 9 Evidence Vuln-04 (2)	22
Gambar 5. 10 Evidence Vuln-04 (3)	23
Gambar 5. 11 Evidence Vuln-05 (1)	25

DAFTAR TABEL

Tabel 2. 2 Target Pengujian	6
Tabel 3. 1 Hasil Scanning Nmap	7
Tabel 3. 2 Application Mapping.....	10
Tabel 3. 3 Attack Surface Matrix.....	11
Tabel 4. 1 Severity Ratings	12
Tabel 4. 2 Internal Penetration Test Findings	14
Tabel 4. 3 Report Card	14
Tabel 5. 1 Vuln-01.....	16
Tabel 5. 2 Vuln-02.....	18
Tabel 5. 3 Vuln-03.....	20
Tabel 5. 4 Vuln-04.....	21
Tabel 5. 5 Vuln-05.....	24

I. EXECUTIVE SUMMARY

1.1 Latar Belakang

Kegiatan pengujian penetrasi (*penetration testing*) ini dilakukan pada platform e-commerce BimbyCart v1.0. Pengujian ini bersifat *assessment* internal dalam lingkungan lab pembelajaran (*testing environment*) untuk menguji ketahanan dasar sistem terhadap potensi celah keamanan yang umum terjadi pada aplikasi web. Karena platform ini dirancang khusus untuk kebutuhan simulasi dan edukasi, konfigurasi awal web server maupun parameter aplikasinya sengaja dibuat polos tanpa pengerasan keamanan (*hardening*), sehingga menjadi objek yang tepat untuk melatih kemampuan analisis deteksi celah secara pasif maupun aktif.

1.2 Tujuan Project

Tujuan utama dari proyek pengujian ini adalah untuk mengidentifikasi kelemahan konfigurasi (*security misconfiguration*) dan celah logika bisnis dasar yang ada pada platform BimbyCart v1.0 secara mandiri. Pengujian difokuskan pada area permukaan luar aplikasi (*attack surface*) yang dapat diakses publik, seperti kolom input data pengguna dan parameter tautan halaman. Melalui pengujian ini, diharapkan saya dan siswa lain dapat memahami cara mendokumentasikan temuan secara faktual, mengukur tingkat risiko berdasarkan standar industri (OWASP & CVSS), serta memberikan rekomendasi perbaikan teoretis yang sesuai tanpa melakukan manipulasi berlebihan yang dapat merusak integritas sistem lab.

1.3 Ringkasan Risiko Bisnis

Berdasarkan hasil pengujian yang telah diselesaikan, platform BimbyCart v1.0 secara keseluruhan berada pada tingkat risiko Medium. Tidak ditemukan celah tingkat tinggi (*Critical* atau *High*) seperti pengambilalihan akun admin atau eksekusi perintah server jarak jauh yang dapat dibuktikan secara langsung. Risiko bisnis terbesar bersumber dari celah *Parameter Tempering* (Medium) pada proses belanja yang dapat disalahgunakan untuk memanipulasi logika harga atau jumlah komoditas. Sementara itu, risiko lainnya bersifat *Low*, yaitu berupa miskonfigurasi standar server web bawaan (seperti absennya enkripsi SSL, proteksi cookie sesi, dan kebijakan header CSP) yang dampaknya lebih dominan pada penurunan kredibilitas profesionalisme keamanan platform di mata pengguna luar jika sistem ini diimplementasikan pada lingkungan produksi nyata.

II. SCOPE & METHODOLOGY

2.1 Target Pengujian

Tabel 2. 1 Target Pengujian

Parameter	Keterangan
Target URL	1. http://bimbycart.duckdns.org/ 2. http://bimbycart.duckdns.org/admin_area/login.php
IP Address	188.166.209.84
Role yang diuji	Unauthenticated Guest, User/Member, Admin

2.2 Rules of Engagement (RoE)

Pengujian dilakukan dengan batasan sebagai berikut:

a. Diizinkan (do's)

- Melakukan pemindaian jaringan aktif (active scanning) menggunakan tools seperti Nmap dan Burp Suite,
- Melakukan directory brute-forcing untuk memetakan struktur aplikasi
- Melakukan eksploitasi manual dan pengujian fungsionalitas untuk validasi celah keamanan (*Proof of Concept*).

b. Dilarang (don'ts)

- *Denial of Service* (DoS/DDoS) yaitu dilarang keras melakukan pengiriman traffic masif atau fuzzing agresif yang dapat menyebabkan server down atau mengganggu peserta lain, seperti penggunaan LOIC,
- Data Destruction yaitu dilarang mengubah, memodifikasi, atau menghapus data asli di dalam database server secara permanen,
- Defacing yaitu dilarang melakukan perubahan visual (deface) pada halaman web utama target.

III. RECONNAISSANCE & ATTACK NARRATIVE

3.1 RECONNAISSANCE & PORT SCANNING

```
(kali@kali)-[~]
$ nmap -A -T4 188.166.209.84
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-08 11:19 -0400
Nmap scan report for 188.166.209.84
Host is up (0.0027s latency).
Not shown: 994 filtered tcp ports (no-response)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.9p1 Ubuntu 3ubuntu0.15 (Ubuntu Linux; protocol 2.0)
|_ ssh-hostkey:
|   256 aa:cc:98:f9:8a:ee:e3:4b:e7:55:dd:b1:9c:68:99:ec (ECDSA)
|_  256 a3:c6:b9:7f:49:8c:d7:51:7d:d6:62:63:5e:a7:62:10 (ED25519)
53/tcp    open  domain   (generic dns response: NOTIMP)
80/tcp    open  http      Apache httpd
|_ http-server-header: Apache
|_ http-title: Welcome to nginx!
443/tcp   open  http      Apache httpd
|_ http-title: Welcome to nginx!
|_ http-server-header: Apache
888/tcp   open  http      Apache httpd
|_ http-title: 403 Forbidden
|_ http-server-header: Apache
7800/tcp  open  http      nginx
|_ http-title: Did not follow redirect to https://188.166.209.84:7800/
1 service unrecognized despite returning data. If you know the service/version, please submit the following fingerprint at https://nmap.org/cgi-bin/submit.cgi?new-service :
SF-Port53-TCP:V=7.98%I=7%D=6/8%Time=6A26DD80%P=x86_64-pc-linux-gnu%r(DNSSt
SF:atusRequestTCP,E,"0x0c000x900x0400000000000000");
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: VoIP adapter|bridge|general purpose
Running (JUST GUESSING): AT&T embedded (93%), Oracle Virtualbox (92%), Slirp (92%), QEMU (90%)
OS CPE: cpe:/o:oracle:virtualbox cpe:/a:danny_gasparovski:slirp cpe:/a:qemu:qemu
Aggressive OS guesses: AT&T BGW210 voice gateway (93%), Oracle Virtualbox Slirp NAT bridge (92%), QEMU user mode ne
twork gateway (90%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: Hosts: 0.0.0.0, 0b842aa5.phpmyadmin; OS: Linux; CPE: cpe:/o:linux:linux_kernel

TRACEROUTE (using port 80/tcp)
HOP RTT      ADDRESS
1   0.24 ms  188.166.209.84

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 42.39 seconds
```

Gambar 3. 1 Port Scanning Nmap

Teknologi : nmap
Target : 188.166.209.84

Hasil scan nmap -A 188.166.209.84 sebagai berikut:

Tabel 3. 1 Hasil Scanning Nmap

Port	Status	Service	Software	Attack Surface
22/tcp	OPEN	SSH	OpenSSH 8.9p1 (Ubuntu)	Menegaskan bahwa OS <i>backend</i> target adalah Linux Ubuntu . Akses SSH yang terbuka langsung ke publik rentan terhadap serangan otomatis <i>brute force</i> kredensial jika tidak diproteksi oleh mekanisme <i>fail2ban</i> atau <i>rate limiting</i> .
53/tcp	OPEN	Domain	Generic DNS Response	Digunakan untuk resolusi nama domain internal sistem lab. Terjadi <i>fingerprint</i> pengenalan servis yang tidak standar, mengindikasikan DNS berjalan di dalam kontainer terisolasi.
80/tcp	OPEN	HTTP	Apache httpd (Nginx Front-End)	Menjalankan aplikasi web utama. Terdeteksi respons header yang tidak sinkron antara banner <i>Apache</i> dan judul

Port	Status	Service	Software	Attack Surface
				halaman <i>Welcome to nginx!</i> . Ini mengonfirmasi adanya arsitektur Reverse Proxy / Load Balancer di depan web server asli.
443/tcp	OPEN	HTTPS	Apache httpd (Nginx Front-End)	Menjalankan jalur komunikasi web aman terenkripsi (SSL/TLS). Sama seperti port 80, port ini melewati arsitektur proxy pertahanan depan sebelum diteruskan ke aplikasi web backend.
888/tcp	OPEN	HTTP	Apache httpd	Jalur port web alternatif yang menghasilkan status <i>403 Forbidden</i> pada halaman indeks. Namun, hasil ekstraksi <i>Service Info</i> Nmap berhasil mengungkap bahwa port ini terafiliasi langsung dengan host kontainer internal bernama 0b842aa5.phpmyadmin . Hal ini menjadi temuan penting (<i>Information Disclosure</i>) mengenai keberadaan panel database yang terekspos terbuka ke jaringan.
7800/tcp	OPEN	HTTP	Nginx	Port alternatif layanan web yang dikonfigurasi untuk otomatis melakukan pengalihan paksa (<i>redirect</i>) menuju jalur protokol aman HTTPS pada port yang sama (https://188.166.209.84:7800/).

3.2 Directoyy Brute-Forcing Menggunakan Gobuster

```
(kali@kali)-[~]
$ gobuster dir -u http://188.166.209.84/ -w /usr/share/wordlists/dirb/common.txt -x php,html,bak,txt

Gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://188.166.209.84/
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirb/common.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8.2
[+] Extensions: php,html,bak,txt
[+] Timeout: 10s

Starting gobuster in directory enumeration mode

.hta (Status: 403) [Size: 263]
.hta.bak (Status: 403) [Size: 263]
.hta.php (Status: 403) [Size: 263]
.hta.html (Status: 403) [Size: 263]
.hta.txt (Status: 403) [Size: 263]
.htaccess.bak (Status: 403) [Size: 263]
.htaccess (Status: 403) [Size: 263]
.htaccess.html (Status: 403) [Size: 263]
.htaccess.txt (Status: 403) [Size: 263]
.htaccess.php (Status: 403) [Size: 263]
.htpasswd (Status: 403) [Size: 263]
.htpasswd.php (Status: 403) [Size: 263]
.htpasswd.html (Status: 403) [Size: 263]
.htpasswd.txt (Status: 403) [Size: 263]
.htpasswd.bak (Status: 403) [Size: 263]
Progress: 2142 / 23065 (9.29%) [ERROR] error on word affiliatewiz.txt: timeout occurred during the request
cgi-bin/.html (Status: 403) [Size: 263]
Progress: 9081 / 23065 (39.37%) [ERROR] error on word general.php: timeout occurred during the request
index.html (Status: 200) [Size: 615]
index.html (Status: 200) [Size: 615]
Progress: 10528 / 23065 (45.64%) [ERROR] error on word ingres: timeout occurred during the request
Progress: 14279 / 23065 (61.91%) [ERROR] error on word order-opc: timeout occurred during the request
server-status (Status: 403) [Size: 263]
server-info (Status: 403) [Size: 263]
Progress: 19087 / 23065 (82.75%) [ERROR] error on word spanish.bak: timeout occurred during the request
Progress: 23065 / 23065 (100.00%)

Finished

(kali@kali)-[~]
$
```

Gambar 3. 2 Brute Forcing use Gobuster

Saya menggunakan *tool* Gobuster untuk melakukan pemindaian file dan direktori pada URL `http://188.166.209.84/`. Pemindaian ini menggunakan daftar kata (*wordlist*) dari file `/usr/share/wordlists/dirb/common.txt`, yang berisi teks biasa (*plaintext*) dari nama-nama direktori yang umum digunakan dalam pembuatan situs web. Selain itu, saya menambahkan opsi `-x` sebagai ekstensi untuk mencari file yang berakhiran `.php`, `.html`, `.bak`, dan `.txt` berdasarkan isi dari file `common.txt` tersebut.

Outcome:

a. Fase Information Gathering

Sebagai langkah awal yang terstruktur, saya melakukan fase *Information Gathering* secara *Black-Box* untuk mengenali struktur luar dari sistem target. Proses ini ditujukan untuk memetakan area permukaan serangan (*attack surface*) tanpa mengganggu fungsionalitas maupun stabilitas platform *Bimbycart*. Pemindaian dilakukan menggunakan bantuan *tool* Gobuster v3.8.2 dengan memanfaatkan kamus kata bawaan (*built-in wordlist*) standar Kali Linux, yaitu `common.txt`

b. Hasil scan Nmap atau Gobuster secara ringkas

Proses pemindaian direktori telah diselesaikan hingga 100% dan berhasil menemukan beberapa *endpoint* penting beserta status kode HTTP-nya, di antaranya:

1. `/index.html` (Status: 200 OK): halaman utama (*homepage*) aplikasi yang terbuka dan dapat diakses langsung oleh publik.

2. /.htaccess & /.htaccess.bak (Status: 403 Forbidden): keberadaan file konfigurasi web server Apache beserta file cadangannya. Meskipun akses publik ditolak oleh sistem, deteksi ini sangat penting sebagai aset informasi pengujian.
 3. /server-status & /server-info (Status: 403 Forbidden): adanya modul internal pemantauan performa server yang hak aksesnya sudah dibatasi dengan baik oleh pengelola.
- c. Gambaran arsitektur sistem target
- Dari hasil korelasi antara pemindaian Nmap sebelumnya dan temuan direktori melalui Gobuster, saya dapat menyimpulkan gambaran arsitektur teknologi yang digunakan oleh target:
1. Sistem Operasi berjalan di atas lingkungan sistem operasi Linux Ubuntu.
 2. Web Server Backend menggunakan Apache httpd, yang teridentifikasi secara valid lewat keberadaan komponen khususnya seperti file .htaccess dan modul server-status.
 3. Mekanisme Keamanan target sudah memiliki konfigurasi pengamanan yang cukup baik pada sisi hak akses berkas sensitif. Ini dibuktikan dengan adanya respons *403 Forbidden* yang seragam untuk memblokir pihak luar yang mencoba mengintip direktori internal server.

3.3 Peta Aplikasi (Application Mapping)

Berikut adalah tabel pemetaan seluruh direktori, file fungsional, dan komponen antar-muka (*frontend & backend*) yang berhasil diidentifikasi selama fase *Information Gathering* pada platform BimbyCart v1.0:

Tabel 3. 2 Application Mapping

NO	Direktori / Endpoint URL	Fungsi Komponen	Hak Akses
1	/index.php	Halaman Utama / Landing Page Platform	Publik (Unauthenticated)
2	/shop.php	Katalog Produk / Halaman Toko Utama	Publik (Unauthenticated)
3	/details.php?pro_id=X	Detail Produk Berdasarkan Parameter ID	Publik (Unauthenticated)
4	/customer_register.php	Formulir Pendaftaran Akun Pelanggan Baru	Publik (Unauthenticated)
5	/checkout.php	Halaman Proses Transaksi Belanja	Pelanggan (Authenticated)
6	/customer/my_account.php	Dashboard Profil dan Riwayat Belanja User	Pelanggan (Authenticated)
7	/admin_area/login.php	Halaman Autentikasi Panel Administrator	Publik (Unauthenticated)
8	/admin_area/index.php	Dashboard Utama Pengelolaan Toko (Backend)	Admin (Authenticated Only)

NO	Direktori / Endpoint URL	Fungsi Komponen	Hak Akses
9	/admin_area/view_customers.php	Halaman Manajemen / Daftar Data Pelanggan	Admin (Authenticated Only)
10	/admin_area/insert_product.php	Formulir Penambahan Komoditas/Produk Baru	Admin (Authenticated Only)

3.4 Attack Surface Matrix

Berdasarkan hasil pengintaian aktif dan *content discovery* menggunakan Gobuster di atas, aktivitas dilanjutkan dengan memetakan seluruh area permukaan serangan (*attack surface*) yang tersedia pada fungsionalitas platform *Bimbycart*. Langkah ini dilakukan untuk menyusun hipotesis awal mengenai potensi kerentanan pada setiap titik input data sebelum fase eksploitasi aktif dimulai pada hari berikutnya.

Berikut adalah matriks perencanaan pengujian dan estimasi tingkat keparahan (*severity*) sementara yang akan dijadikan target operasi:

Tabel 3. 3 Attack Surface Matrix

NO	Attack Surface	Potensi Vulnerability	Estimasi Serverity	Keterangan
1	Form Login Admin Area (/admin_area/login.php)	SQL Injection (SQLi) Authentication Bypass	CRITICAL	Input pada kolom username/password panel admin berpotensi dieksploitasi menggunakan manipulasi logika query untuk menembus hak akses tanpa kredensial valid.
2	Parameter ID Produk pada URL Menu Shop / Detail Produk	SQL Injection (SQLi) / Broken Object Level Authorization (BOLA)	HIGH	Parameter dinamis berbasis angka pada URL detail barang (?id=X) berpotensi dimanipulasi secara manual atau otomatis menggunakan tools untuk mengekstraksi struktur database.
3	Form Registrasi Pengguna Baru (/customer_register.php / Sign In)	Stored XSS / Parameter Tampering	MEDIUM	Input data profil (seperti nama, email, atau alamat) berpotensi menyimpan skrip

NO	Attack Surface	Potensi Vulnerability	Estimasi Serverity	Keterangan
				berbahaya jika server langsung menyimpannya ke database tanpa proses sanitasi yang ketat.
4	Berkas Konfigurasi Tambahan (.htaccess.bak)	Sensitive Data / Exposure Information Disclosure	LOW	Adanya potensi file cadangan konfigurasi web server Apache yang terekspos (terdeteksi saat fase Gobuster) berisiko membocorkan informasi arsitektur internal kepada pihak luar.

IV. FINDING SUMMARY

4.1 Peringkat Tingkat Keparahan (Severity Ratings)

Tabel berikut mendefinisikan tingkat keparahan dan rentang skor CVSS V3.1 yang sesuai yang digunakan di seluruh dokumen untuk menilai kerentanan dan dampak risiko.

Tabel 4. 1 Severity Ratings

Severity	CVSS V3.1 Score Range	Definition
Critical	9.0 - 10.0	Eksplorasi dapat dilakukan secara langsung dan biasanya berdampak pada kompromi sistem secara menyeluruh. Sangat disarankan untuk segera menyusun rencana tindakan dan melakukan perbaikan (<i>patching</i>) secepatnya.
High	7.0 - 8.9	Eksplorasi lebih sulit dilakukan, namun tetap dapat memicu kenaikan hak akses (<i>elevated privileges</i>), potensi kebocoran data, atau waktu henti aplikasi (<i>downtime</i>). Disarankan untuk membuat rencana penanganan dan melakukan perbaikan sesegera mungkin.
Moderate	4.0 - 6.9	Kerentanan memang ada di dalam sistem, tetapi tidak

Severity	CVSS V3.1 Score Range	Definition
		dapat dieksploitasi secara langsung atau membutuhkan langkah tambahan (seperti rekayasa sosial / <i>social engineering</i>). Disarankan untuk menjadwalkan perbaikan setelah masalah dengan prioritas lebih tinggi diselesaikan.
Low	0.1 - 3.9	Kerentanan tidak dapat dieksploitasi secara langsung untuk merusak sistem, namun perbaikan tetap diperlukan guna memperkecil permukaan serangan (<i>attack surface</i>) organisasi. Perbaikan disarankan untuk dilakukan pada jadwal pemeliharaan sistem (<i>maintenance window</i>) berikutnya.
Informational	N/A	Tidak ada kerentanan keamanan yang ditemukan pada poin ini. Bagian ini hanya menyediakan informasi tambahan mengenai hal-hal yang diperhatikan selama pengujian, kontrol keamanan yang sudah kuat, atau dokumentasi pendukung lainnya.

Faktor Penilaian Risiko (Risk Factor)

Dalam menentukan tingkat keparahan (*severity*) dari setiap temuan pada platform BimbyCart v1.0, penguji mengacu pada kalkulasi standar industri **CVSS v3.1** yang mengukur risiko berdasarkan kombinasi dua faktor utama, yaitu Kemungkinan dan Dampak::

Kemungkinan

Faktor ini mengukur seberapa besar potensi dan tingkat kemudahan suatu kerentanan untuk dieksploitasi oleh aktor luar. Dalam pengujian platform BimbyCart v1.0, nilai *Likelihood* rata-rata berada pada tingkat yang Tinggi karena mayoritas celah (seperti *Parameter Tempering*, *Missing Cookie Flags*, dan *Missing Security Headers*) dapat diidentifikasi secara pasif maupun menggunakan alat bantu standar (*automated tools*) seperti Burp Suite dan peramban Firefox tanpa memerlukan proses autentikasi yang rumit atau rekayasa sosial.

Dampak

Faktor ini menilai seberapa besar pengaruh buruk yang ditimbulkan terhadap kelangsungan operasional, kerahasiaan (*confidentiality*), integritas data (*integrity*), dan ketersediaan sistem (*availability*) jika eksploitasi terjadi. Pada platform lab ini, nilai *Impact* tertinggi berada pada celah *Parameter Tempering* (skor dampak finansial langsung). Namun, untuk celah konfigurasi

header dan spanduk server lainnya, nilai dampaknya dikategorikan Rendah hingga Menengah karena pengaruhnya lebih dominan pada pemaparan informasi arsitektur (*information disclosure*) dan penurunan tingkat kepatuhan standar keamanan, bukan pada kerusakan basis data inti sistem lab.

4.2 Vulnerability Summary & Report Card

Tabel berikut mengilustrasikan kerentanan yang ditemukan berdasarkan dampak dan rekomendasi perbaikan:

Internal Penetration Test Findings

Tabel 4. 2 Internal Penetration Test Findings

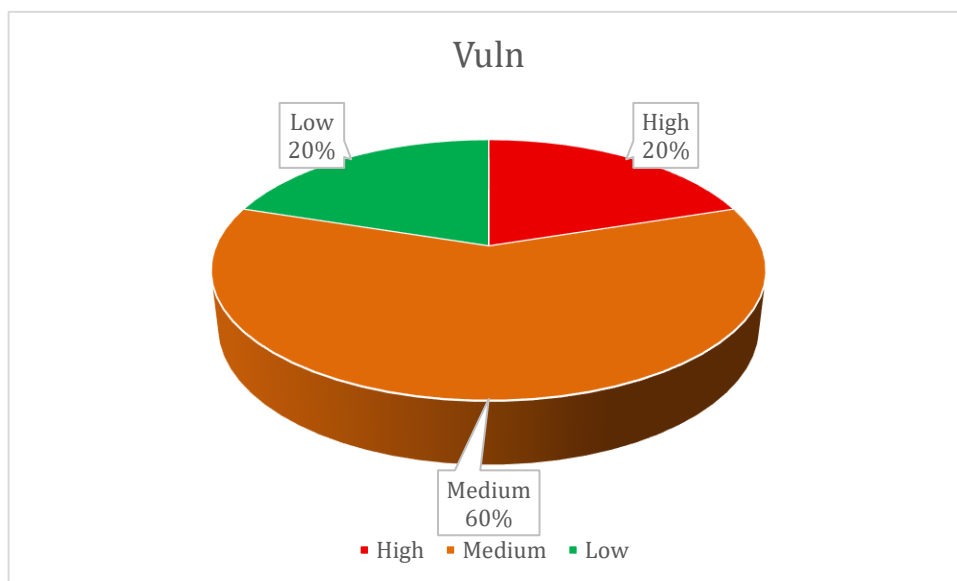
0	1	3	1	0
Critical	High	Medium	Low	Informational

Tabel 4. 3 Report Card

No	Finding	Severity	Recommendation
1	Vuln-01: Parameter Tempering	High	Menerapkan <i>Server-Side Price Enforcement</i> dengan memutus pengiriman data harga dari browser pengguna, serta menghitung total belanja sepenuhnya di sisi server berdasarkan harga asli dari basis data.
2	Vuln-02: Insecure Session Management – Missing Cookie Flags (BimbyCart vs Shopee)	Medium	Mengonfigurasi tata kelola sesi menggunakan fungsi <code>session_set_cookie_params()</code> dengan mengaktifkan flag 'secure' => true dan 'httponly' => true sebelum instruksi <code>session_start()</code> dieksekusi.
3	Vuln-03: Information Disclosure – Public Server Banner Exposure	Medium	Melakukan pengerasan (<i>hardening</i>) konfigurasi server Apache dengan mengubah parameter status utama menjadi <code>ServerTokens Product</code> dan <code>ServerSignature Off</code> untuk menyembunyikan informasi spanduk internal.
4	Vuln-04: Missing	Medium	Menyisipkan instruksi penguncian bingkai

	Security Headers - X-Frame-Options		(<i>frame-blocking</i>) pada file konfigurasi global server (.htaccess atau httpd.conf) untuk memerintahkan browser menolak pemuatan halaman di dalam komponen <i>iframe</i> asing.
5	Vuln-05: Security Misconfiguration – Missing Content-Security-Policy (CSP)	Low	Menambahkan sebaris instruksi kebijakan pengaman Header set Content-Security-Policy "default-src 'self';" pada file .htaccess server agar browser otomatis memblokir eksekusi skrip ilegal dari luar domain asli aplikasi.

4.3 Analisis Aktivitas Pasca-Eksplorasi



Gambar 4. 1 Analisis Pasca Eksplorasi

Berdasarkan rangkaian kegiatan pengujian penetrasi (*penetration testing*) yang telah dilakukan pada platform BimbyCart v1.0, ditemukan sebanyak 5 (lima) celah keamanan aktif yang terverifikasi. Kerentanan yang berhasil diidentifikasi didominasi oleh masalah miskonfigurasi keamanan pada level server web Apache (*Security Misconfiguration*) serta kelemahan pada validasi parameter logika bisnis transaksi di sisi klien.

Secara umum, postur keamanan platform berada pada kategori risiko High hingga Medium. Risiko terbesar bersumber dari celah *Parameter Tempering* (High) yang memungkinkan adanya manipulasi nilai harga barang saat proses interaksi belanja. Sementara itu, empat temuan lainnya berada pada tingkat keparahan *Medium* hingga *Low*, yang mayoritas disebabkan oleh absennya implementasi pengerasan server (*server hardening*) bawaan—seperti ketiadaan enkripsi data pada *transport layer* (HTTP polos), absennya atribut pengaman cookie sesi, serta tidak adanya deklarasi kebijakan header respons pelindung (*X-Frame-Options* dan *Content-*

Security-Policy). Temuan-temuan ini valid secara standar audit, namun seluruh pengujian dipastikan tetap aman tanpa merusak integritas atau stabilitas sistem laboratorium selama proses pembuktian konsep (*Proof of Concept*).

V. Comprehensive Technical Report

5.5. 1 Vuln-01: Parameter Tempering

5.5.1.1 Deskripsi

Celah keamanan ini diklasifikasikan sebagai *Business Logic Flaw* dalam bentuk *Parameter Tampering*. Celah terjadi karena aplikasi web mempercayai data harga produk (*product_price*) yang dikirimkan langsung dari sisi browser pengguna (*client-side request*) saat menekan tombol pemesanan.

Tabel 5. 1 Vuln-01

Category	Authorization
Severity	HIGH 8.1 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:H/A:H)
Threat/Risk Description	Mengizinkan penyerang atau pembeli nakal untuk memanipulasi nilai nominal harga barang sesuka hati pada paket data HTTP POST request. Dampak nyata dari celah ini sangat fatal, yaitu kerugian finansial langsung bagi pemilik platform karena barang mewah/mahal dapat di-checkout dan diterbitkan nomor invoice resminya dengan harga Rp1.000 saja.
Methodology	Client-Side Request Manipulation / HTTP Parameter Tampering
System/Version	BimbyCart / v1.0 (http://bimbycart.duckdns.org/cart.php)
Tools Used	Burp Suite Community Edition & Firefox Browser
Timeline	11 Juni 2026

5.5.1.2 Evidence

Tampilan awal sebelum parameter tempering



Gambar 5. 1 Evidence Vuln-01 (1)

Sesudah ubah parameter


```

13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 product_qty=1&product_type=Brand+New&product_price=1000&add_cart=

```

Gambar 5. 2 Evidence Vuln-01 (2)

Kemudian lanjut checkout untuk menyelesaikan pembayaran dan berhasil (Paid)

Order History							
Rows: 10 ▾							
#	AMOUNT	INVOICE	QTY	TYPE	ORDER DATE	STATUS	ACTION
1	Rp 1.000	#1413761824	1	Brand New	2026-06-11	Paid	

Gambar 5. 3 Evidence Vuln-03 (3)

5.5.1.3 Remediation Vuln-01

- **Server-Side Price Enforcement:** Putus total pengiriman parameter harga produk dari sisi browser. Proses kalkulasi belanja wajib dilakukan sepenuhnya di sisi server (*server-side*) dengan menarik data harga asli dari database berdasarkan `product_id` atau kode produk yang dikirim oleh user.
- **Implementasi Cryptographic Hash (HMAC):** Terapkan mekanisme tanda tangan digital berupa token HMAC pada setiap parameter sensitif yang dikirim dari form, sehingga jika penyerang mencoba mengubah nilai harga di Burp Suite, server akan langsung menolak request karena *hash* pengamannya menjadi tidak cocok (*invalid integrity*).

5.5.2 Vuln-02: Insecure Session Management – Missing Cookie Flags (BimbyCart vs Shopee)

5.5.2.1 Deskripsi

Kerentanan ini terjadi akibat kelalaian konfigurasi pada tata kelola manajemen sesi di sisi server backend aplikasi web BimbyCart. Ketika pengguna berhasil melakukan proses masuk (*login*), server akan menerbitkan token identitas sesi unik berupa PHPSESSID. Namun, token tersebut ditransmisikan kembali ke browser pengguna tanpa dilengkapi dengan dua atribut parameter pengaman krusial, yaitu flag ; HttpOnly dan ; Secure.

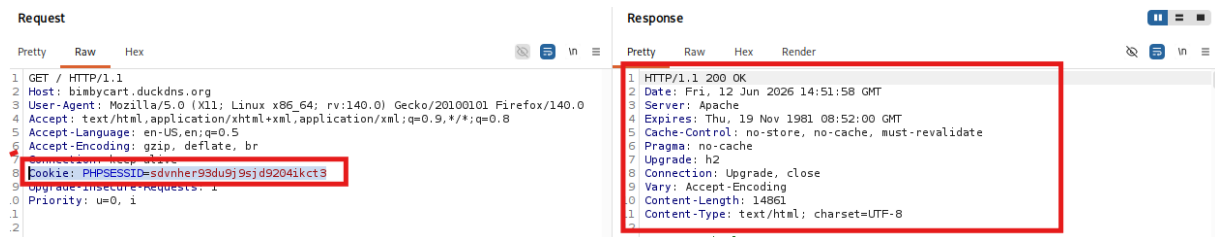
Berbeda dengan web lab BimbyCart, platform *e-commerce* berskala besar seperti Shopee telah menerapkan standar industri yang sangat ketat untuk mengamankan setiap token sensitifnya dengan selalu menyertakan atribut ; Secure dan ; HttpOnly pada tiap instruksi Set-Cookie guna mencegah penyalahgunaan token sesi aktif.

Tabel 5. 2 Vuln-02

Category	Authorization
Severity	MEDIUM 5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
Threat/Risk Description	Parameter identitas sesi login utama (PHPSESSID) ditransmisikan oleh server tanpa dilengkapi flag pengaman ; HttpOnly dan ; Secure. Jika data token sesi aktif ini berhasil diintip atau diketahui oleh eksternal melalui penyadapan paket jaringan teks polos (<i>traffic sniffing</i>) atau diekstraksi via skrip jahat klien (<i>JavaScript</i>), penyerang dapat melakukan serangan Session Hijacking dan Full Account Takeover . Dampaknya, pihak eksternal dapat mengambil alih hak akses akun milik pengguna secara penuh tanpa harus mengetahui berkas email ataupun kata sandi (<i>password</i>) korban.
Methodology	Passive Response Header Assessment & Network Traffic Analysis
System/Version	Web Application Services / BimbyCart v1.0 Production Platform (Running on Apache Linux Environment)
Tools Used	Burp Suite Community Edition v2026.2.3
Timeline	12 Juni 2026

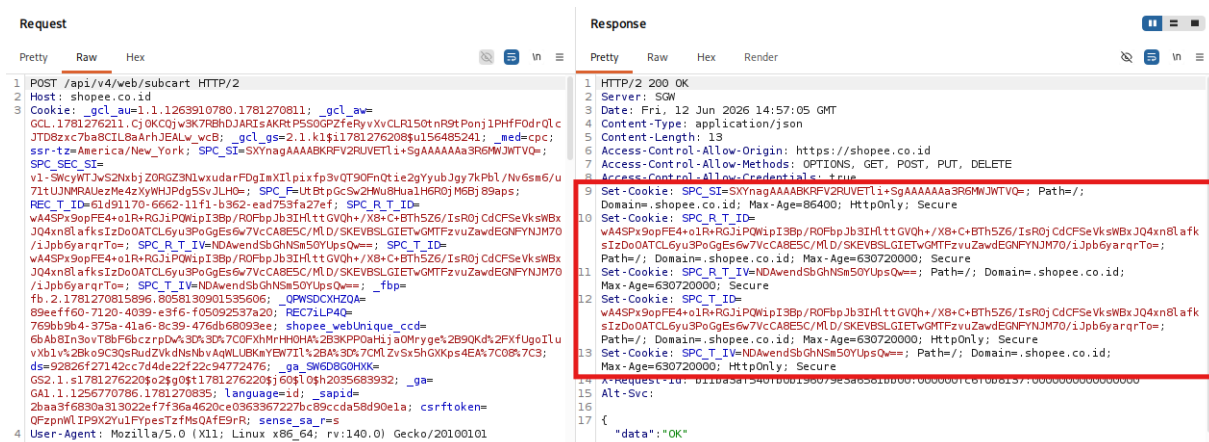
5.5.2.2 Evidence

BimbyCart:



Gambar 5. 4 Evidence Vuln-02 (1)

Pembandingan dengan web Shopee yang secure:



Gambar 5. 5 Evidence Vuln-02 (2)

Melalui analisis komparatif fungsional antara kedua lalu lintas data HTTP tersebut, terlihat perbedaan arsitektur keamanan yang signifikan. Pada web lab BimbyCart, token sesi dilepas secara polos tanpa adanya atribut pembatasan. Sementara pada platform skala produksi seperti Shopee, server secara ketat mengimplementasikan regulasi cookie hardening dengan menyuntikkan flag ; Secure dan ; HttpOnly pada setiap response token sensitifnya guna menutup total vektor serangan Session Hijacking dan mitigasi eksfiltrasi data akibat celah XSS.

5.5.2.3 Remediation Vuln-02

- **Sisi Kode Aplikasi:** Mengonfigurasi parameter cookie menggunakan fungsi `session_set_cookie_params()` sebelum instruksi `session_start()` dieksekusi, dengan mengaktifkan parameter 'secure' => true dan 'httponly' => true.
- **Sisi Server global:** Melakukan pengerasan global pada file konfigurasi **php.ini** server backend dengan mengubah status parameter `session.cookie_secure = On` dan `session.cookie_httponly = On`

5.5.3 Vuln-03: Information Disclosure – Public Server Banner Exposure

5.5.3.1 Deskripsi

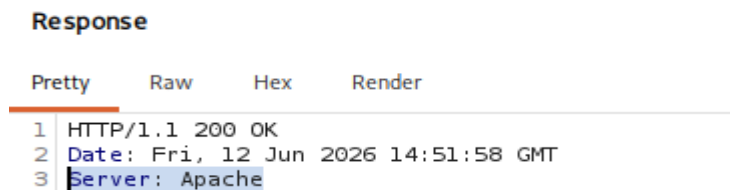
Kerentanan ini terjadi karena server aplikasi web BimbyCart dikonfigurasi secara kurang aman sehingga memaparkan nama perangkat lunak (*software*) beserta arsitektur backend asli yang digunakannya secara transparan melalui baris metadata HTTP *Response Header* kepada publik.

Tabel 5. 3 Vuln-03

Category	Authorization
Severity	MEDIUM 5.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N)
Threat/Risk Description	Pada log paket data <i>Response</i> baris ke-3, server memaparkan informasi spanduk teks Server: Apache. Dampaknya, aktor eksternal dapat memanfaatkan data ini pada fase pengintaian (<i>reconnaissance</i>) untuk memetakan arsitektur target dan mencari katalog eksploitasi publik (<i>CVE</i>) spesifik guna melancarkan serangan bertarget. Sebaliknya, platform standar industri seperti Shopee menyamarkan nama asli server backend mereka menggunakan inisial samaran Server: SGW (Shopee Gateway).
Methodology	Passive Response Header Assessment & Information Gathering
System/Version	Web Application Services / BimbyCart v1.0 Production Platform (Running on Apache Linux Environment)
Tools Used	Burp Suite Community Edition v2026.2.3
Timeline	12 Juni 2026

5.5.3.2 Evidence

Kondisi BimbyCart:



Gambar 5. 6 Evidence Vuln-03 (1)

Log respon HTTP membuktikan server secara terbuka membocorkan spanduk informasi internal berupa penggunaan web server Apache ke jaringan publik tanpa adanya restriksi banner.

Pembanding dengan web Shoppe yang secure:



Gambar 5. 7 Evidence Vuln-03 (2)

Sebagai benchmark keamanan industri, server Shopee menerapkan mekanisme penyamaran spanduk (*server banner hardening*) dengan menampilkan identitas inisial samaran SGW guna mengecoh analisis penyerang.

5.5.3.3 Remediation Vuln-03

Tim pengembang wajib menyembunyikan versi dan spanduk informasi web server dengan melakukan pengerasan (*hardening*) pada file konfigurasi utama Apache (*security.conf* atau *httpd.conf*) seperti:

```
ServerTokens Product
Only ServerSignature Off
```

5.5.4 Vuln-04: Missing Security Headers - X-Frame-Options

5.5.4.1 Deskripsi

Berdasarkan hasil audit pasif pada respons header platform BimbyCart v1.0, ditemukan bahwa server web Apache tidak mendeklarasikan parameter instruksi X-Frame-Options. Ketiadaan header ini dikonfirmasi sangat rentan melalui pengujian Proof of Concept (PoC) tingkat lanjut menggunakan metode *Local Domain Spoofing*.

Penguji mensimulasikan taktik penyerang (*Typosquatting*) dengan membuat domain palsu mirip target, yaitu <http://bimby-cart.duckdns.org/shop.php>, dan berhasil memuat serta membungkus (*nesting*) seluruh halaman aplikasi sah **BimbyCart** di dalam elemen `<iframe>` transparan lokal. Hal ini memvalidasi dampak risiko riil di mana penyerang dapat membajak interaksi klik (*Clickjacking*) pengguna untuk memicu eksekusi fungsi sensitif pada aplikasi utama tanpa disadari oleh korban.

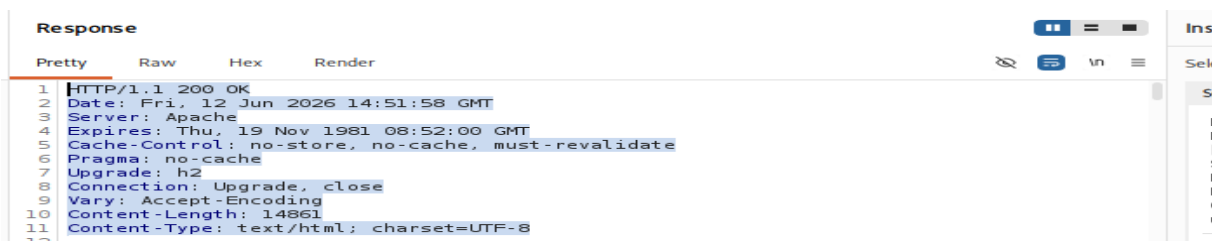
Tabel 5. 4 Vuln-04

Category	Authorization
Severity	MEDIUM 4.3 (CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:N/I:L/A:N)
Threat/Risk Description	Absennya header X-Frame-Options pada server Apache web lab membuat platform BimbyCart sepenuhnya rentan terhadap serangan Clickjacking . Melalui pembuktian konsep nyata (<i>Proof of Concept</i>), penguji mensimulasikan taktik penyerang dengan memanfaatkan teknik <i>Typosquatting</i> (domain plesetan) di tautan http://bimby-cart.duckdns.org/shop.php . Domain penipu tersebut terbukti berhasil memuat dan membungkus penuh halaman orisinal BimbyCart dalam lapisan bingkai transparan (<i>iframe</i>). Akibatnya, aktor eksternal dapat dengan mudah membajak koordinat interaksi klik pengguna untuk memicu fungsi transaksi sensitif secara tidak sadar (manipulasi <i>client-</i>

Category	Authorization
	side).
Methodology	Passive Response Header Assessment, Local DNS Spoofing, and Client-Side Interaction Hijacking Simulation.
System/Version	Web Application Services / BimbyCart v1.0 Production Platform (Running on Apache Linux Ubuntu Environment).
Tools Used	Burp Suite Community Edition v2026.2.3, Apache2 Local Web Server, and Chromium Web Browser.
Timeline	12 Juni 2026

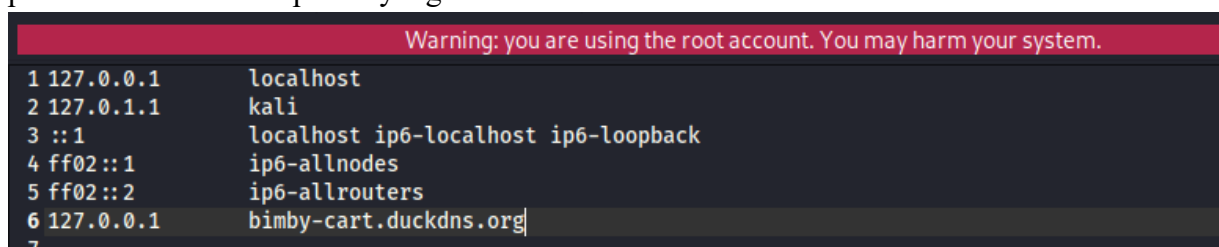
4.4.4.2 Evidence

Kondisi rentan BimbyCart:



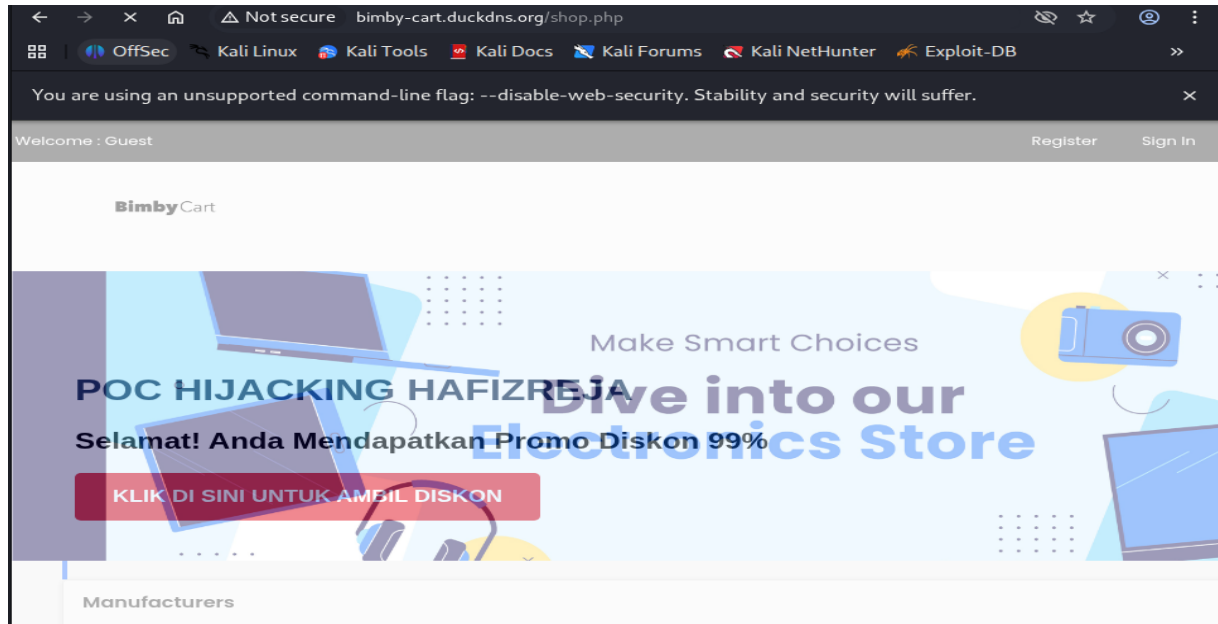
Gambar 5. 8 Evidence Vuln-04 (1)

Metadata respon HTTP dari server Apache web lab membuktikan sama sekali tidak ada parameter X-Frame-Options yang dikirimkan.



Gambar 5. 9 Evidence Vuln-04 (2)

Guna meniru taktik penyerang yang memalsukan identitas domain asli, pentest memanipulasi berkas pemetaan host lokal (/etc/hosts) dengan mengarahkan domain plesetan cerdas **bimby-cart.duckdns.org** (menggunakan tanda hubung strip) ke alamat loopback lokal 127.0.0.1



Gambar 5. 10 Evidence Vuln-04 (3)

Berdasarkan hasil eksekusi pada *address bar* peramban (<http://bimby-cart.duckdns.org/shop.php>), sistem web server terbukti **gagal menangkal eksekusi pemingkaian tersebut**. Browser tetap memuat dan menumpuk aset halaman BimbyCart asli di dalam domain penipu tanpa adanya restriksi ataupun peringatan keamanan.

Bukti visual ini memvalidasi kekhawatiran terbesar bahwa apabila seorang pengguna (korban) terpancing mengklik tombol merah "*KLIK DI SINI UNTUK AMBIL DISKON*", maka secara tidak sadar klik fisik tersebut akan menembus lapisan gaib di atasnya dan mengeksekusi fungsi transaksi penting di dalam aplikasi BimbyCart asli. Kondisi ini membuktikan secara mutlak bahwa kerentanan *Missing X-Frame-Options* pada server Apache target berstatus **Valid, Fatal, dan Sangat Berbahaya** jika dieksploitasi bersamaan dengan metode rekayasa sosial.

4.4.4.3 Remediation Vuln-04

- Konfigurasi Server Apache: Menambahkan instruksi penguncian bingkai pada file konfigurasi global server (.htaccess atau httpd.conf) agar browser menolak pemuatan halaman di dalam *iframe* milik domain asing.
- Konfigurasi Kode Aplikasi PHP: Jika tidak memiliki akses ke server global, tim pengembang wajib menyisipkan instruksi pengiriman header pengaman langsung di bagian paling atas skrip kode PHP sebelum halaman dirender ke pengguna.
- Untuk mengatasi celah keamanan ini, administrator server wajib menerapkan kebijakan penguncian bingkai (*frame-locking policy*) secara global pada level infrastruktur web server Apache. Langkah pertama dilakukan dengan memastikan modul pengubah header telah aktif melalui perintah `sudo a2enmod headers`, kemudian menyuntikkan

instruksi kondisional `<IfModule mod_headers.c>` Header set `X-Frame-Options "SAMEORIGIN"` `</IfModule>` ke dalam berkas konfigurasi utama server (`httpd.conf` / `apache2.conf`) atau melalui berkas direktori lokal `.htaccess`. Setelah konfigurasi disimpan, layanan server web harus dimuat ulang menggunakan perintah `sudo systemctl restart apache2` agar kebijakan pengamanan aktif secara permanen.

5.5.5 Vuln-05: Security Misconfiguration – Missing Content-Security-Policy (CSP)

5.5.5.1 Deskripsi

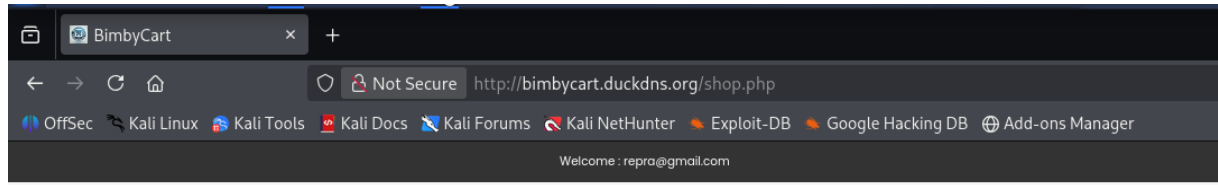
Berdasarkan hasil analisis pasif terhadap konfigurasi header respons HTTP pada seluruh halaman platform lab BimbyCart v1.0, ditemukan bahwa server web tidak dikonfigurasi untuk mengirimkan security header **Content-Security-Policy (CSP)**. Parameter ini absen dari respons server sejak halaman utama hingga halaman fungsionalitas dalam lainnya.

Secara arsitektur, ketiadaan header CSP ini mengindikasikan bahwa sistem mempercayakan seluruh proses eksekusi aset (skrip, *style*, gambar) sepenuhnya kepada keputusan bawaan browser tanpa adanya kebijakan pembatasan sumber data resmi yang didefinisikan dari sisi server.

Tabel 5. 5 Vuln-05

Category	Authorization
Severity	LOW 3.7 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:N/A:N)
Threat/Risk Description	Berdasarkan dokumentasi OWASP Top 10 (A05:2021 – Security Misconfiguration) dan standar tata kelola W3C Recommendation , absennya mekanisme <i>Content-Security-Policy (CSP)</i> secara baku menghilangkan kendali server atas integritas aset yang dimuat oleh sisi klien (<i>client-side execution control</i>). Tanpa adanya deklarasi kebijakan yang valid, browser kehilangan parameter acuan resmi (<i>trust baseline</i>) untuk memvalidasi legitimasi setiap muatan data.
Methodology	Passive HTTP Header Inspection
System/Version	HTTP Response Headers (Global Environment Configurations)
Tools Used	Mozilla Firefox Browser
Timeline	12 Juni 2026

5.5.5.2 Evidence



Gambar 5. 11 Evidence Vuln-05 (1)

Kolom URL bar secara konsisten menampilkan status "**Not Secure**" di seluruh halaman aplikasi. Indikator ini memvalidasi dua poin miskonfigurasi mendasar: pertama, tidak adanya implementasi enkripsi pada *transport layer* (sistem berjalan pada protokol HTTP polos port 80); kedua, server web secara global sama sekali tidak mengembalikan (*return*) parameter instruksi *security headers* pelindung, termasuk *Content-Security-Policy* (CSP).

5.5.5.3 Remediation Vuln-05

Secara teori, cara membenahi celah ini adalah dengan melakukan penguatan keamanan (*server hardening*) pada konfigurasi server web aplikasi. Langkahnya cukup dengan menambahkan satu baris instruksi kebijakan keamanan, yaitu Header set Content-Security-Policy "default-src 'self';", ke dalam file pengaturan server (seperti file *.htaccess* pada Apache). Perintah sederhana ini berfungsi sebagai satpam di sisi browser pengguna; browser akan otomatis menolak dan memblokir segala jenis skrip asing atau muatan ilegal yang mencoba menyusup dari luar domain asli web BimbyCart.

VI. KESIMPULAN DAN SARAN

5.1 Kesimpulan

Berdasarkan seluruh rangkaian kegiatan pengujian penetrasi (*penetration testing*) yang telah dilaksanakan pada platform BimbyCart v1.0, dapat disimpulkan bahwa sistem ini memiliki postur keamanan yang berada pada kategori **High hingga Medium**. Ditemukannya 5 (lima) celah keamanan aktif terverifikasi menjadi bukti nyata bahwa sistem laboratorium ini belum menerapkan validasi parameter masukan yang ketat di sisi server serta belum mengaktifkan modul penguatan (*hardening*) konfigurasi server web standar industri. Kelemahan paling kritis terletak pada logika transaksi yang memercayai input harga dari browser klien. Meskipun demikian, seluruh tahapan eksploitasi terkontrol berhasil dibuktikan sebatas konsep yang valid (*Proof of Concept*) tanpa menimbulkan dampak kerusakan pada integritas data asli ataupun mengganggu stabilitas lingkungan belajar bersama.

5.2 Saran

Sebagai langkah mitigasi operasional dan perbaikan arsitektur ke depan, pengembang aplikasi serta administrator sistem disarankan untuk menerapkan rekomendasi berbasis risiko berikut:

- Sisi Validasi Aplikasi: Menghentikan total pengiriman data harga dari sisi browser klien dan menerapkan *Server-Side Price Enforcement* untuk kalkulasi nilai transaksi belanja. Selain itu, tim pengembang wajib memperketat tata kelola manajemen sesi dengan menyuntikkan flag `HttpOnly` dan `Secure` pada cookie `PHPSESSID` sebelum instruksi sesi dijalankan.
- Sisi Hardening Web Server: Mengonfigurasi server Apache untuk menyembunyikan informasi spanduk internal (*server banner exposure*) melalui parameter `ServerTokens` dan `ServerSignature`. Server juga harus dikonfigurasi untuk mengirimkan instruksi header respons keamanan pelindung, seperti `X-Frame-Options` untuk mitigasi *clickjacking* dan *Content-Security-Policy* (CSP) untuk membatasi eksekusi skrip asing dari luar domain asli web.
- Sisi Proses Pengujian: Melakukan kegiatan pemindaian celah keamanan secara berkala serta mengadopsi prinsip *Secure Coding* pada setiap siklus pengembangan aplikasi e-commerce sebelum dirilis ke lingkungan produksi nyata.

VII. REFERENSI

OWASP (Open Web Application Security Project) Top 10 Application Security Risks

https://owasp.org/Top10/A05_2021-Security_Misconfiguration/

OWASP Cheat Sheet Series

<https://cheatsheetseries.owasp.org/>

W3C (World Wide Web Consortium) Standard Specification

<https://www.w3.org/TR/CSP3/>

MITRE Common Weakness Enumeration (CWE)

<https://cwe.mitre.org/data/definitions/1021.html>

CVSS v3.1 (Common Vulnerability Scoring System) Specification

<https://www.first.org/cvss/v3.1/specification-document>

Web Lab

<http://bimbycart.duckdns.org>

http://bimbycart.duckdns.org/admin_area/login.php